

Análise de Vulnerabilidade e Pentest

sexta-feira, 10 de abril de 2026 10:59

Definição e metodologia do pentest

- ▶ O pentest, ou teste de penetração, é uma metodologia de segurança cibernética que visa avaliar a segurança de sistemas, redes, aplicativos e infraestrutura de TI por meio da simulação de ataques cibernéticos controlados.

O objetivo principal do pentest é identificar e explorar vulnerabilidades e fraquezas potenciais em um ambiente de TI, permitindo que as organizações corrijam esses problemas antes que cibercriminosos possam explorá-los. Pentest é uma abordagem proativa para garantir a segurança cibernética.

A metodologia de pentest envolve as seguintes etapas principais:

A coleta de informações, que é a primeira etapa, consiste em coletar informações sobre o sistema, a rede ou o aplicativo que será testado. Isso pode incluir a identificação de alvos, informações sobre a infraestrutura, sistemas operacionais, aplicativos e quaisquer outras informações relevantes.

Em seguida, vem a análise de vulnerabilidades, fase em que o testador realiza uma análise minuciosa do ambiente alvo em busca de vulnerabilidades conhecidas e potenciais. Isso pode envolver a varredura de portas, avaliação de configurações de segurança, análise de códigos-fonte, entre outras técnicas.

A terceira fase é o planejamento de ataques que, com base nas informações coletadas e nas vulnerabilidades identificadas, consiste em o testador elaborar um plano de ataque detalhado. Esse plano descreve como as vulnerabilidades serão exploradas para simular possíveis ataques.

A quarta etapa é a execução de ataques. Nessa fase, os testadores tentam explorar as vulnerabilidades identificadas de acordo com o plano de ataque. O objetivo é verificar se as medidas de segurança existentes são capazes de detectar e contê-los.

A quinta etapa é a documentação e relatório, pois, durante e após o pentest, os testadores documentam todas as atividades realizadas, os resultados obtidos e as recomendações para melhorias. Um relatório completo é entregue ao cliente, que detalha as vulnerabilidades identificadas e fornece orientações sobre como mitigá-las.

A última etapa é a discussão e melhorias. Após a entrega do relatório, o cliente e os testadores geralmente se reúnem para discutir os resultados e planejar as ações corretivas. As vulnerabilidades identificadas podem ser corrigidas e melhorias na segurança podem ser implementadas.

O pentest é uma parte fundamental das estratégias de segurança cibernética para organizações, pois ajuda a identificar e resolver vulnerabilidades antes que elas possam ser exploradas por cibercriminosos. É importante notar que o pentest é uma atividade ética e autorizada, realizada por profissionais de segurança experientes, com o objetivo de fortalecer a segurança dos sistemas e proteger dados sensíveis.

Análise de vulnerabilidades

Com os ambientes em constante mudança e a cada vez mais integrando novas tecnologias, há sempre novas vulnerabilidades nos novos ativos das empresas.

Há diferentes testes de segurança, como as análises e avaliações de riscos, e as análises de vulnerabilidades, que focam tradicionalmente em aspectos tecnológicos.

Para a Open Web Application Security Project (Owasp), que é uma organização dedicada à segurança de aplicativos web e sem fins lucrativos, teste de segurança é o processo de comparar o estado de um sistema ou aplicação de acordo com um conjunto de critérios (Meucci; Muller, 2014). Eles podem ser realizados no final do desenvolvimento ou fazer parte do ciclo de desenvolvimento desde o início, com a implementação de requisitos e testes de segurança automatizados (Mueller; Schleier; Willemsen, 2019).

Para realização de análise e testes de intrusão, diversas ferramentas e muito conhecimento são necessários. Temos uma distribuição de fonte aberta, a Kali Linux, que pode auxiliar na área de testes e segurança, softwares voltados para a análise de vulnerabilidades, como o Nmap, Nessus e Metasploit, OpenVas, Vulnerability Manager Plus, que permitem mapear e indicar as vulnerabilidades, com suas implicações e gravidade em relação aos riscos de invasão.

Outra ferramenta que temos é o Burp Suite, uma plataforma integrada para a realização de testes de segurança em aplicações web. Suas diversas opções funcionam perfeitamente em conjunto para apoiar todo o processo de testes, de mapeamento e análise de superfície de ataque de uma requisição inicial até encontrar e explorar vulnerabilidades de segurança (Prtswigger, 2018).

Mas não basta verificar as vulnerabilidades e parar por aí. É necessário mapear a margem de exploração de um atacante, bem como aplicar os processos de correção adequados, podendo executar pentest para validar se a vulnerabilidade é explorável.

A análise de vulnerabilidades compreende a busca por vulnerabilidades nos ativos de uma forma manual ou com o uso de ferramentas automatizadas, como os *scanners*. **Os tipos de análise de vulnerabilidades são as análises estática e dinâmica** (Koussa, 2018).

A análise estática, ou Static Application Security Testing (SAST), envolve a análise dos componentes do sistema sem a sua execução, pela análise manual ou automatizada do código-fonte. A análise manual exige proficiência na linguagem e no framework usado pela aplicação, e possibilita a identificação de

vulnerabilidades na lógica dos negócios, violações de padrões e falhas na especificação, especialmente quando o código é tecnicamente seguro, mas com falhas na lógica, que são difíceis de serem detectadas por ferramentas automatizadas. Já a análise automatizada é feita com ferramentas que checam o código-fonte por conformidade com um conjunto pré-definido de regras ou melhores práticas da indústria (Mueller; Schleier; Willemsen, 2019).

A análise dinâmica, ou Dynamic Application Security Testing (DAST), envolve a análise do sistema durante a sua execução, em tempo real, de forma manual ou automatizada. Normalmente a análise dinâmica não provê as mesmas informações que a análise estática provê, mas detecta elementos sob o ponto de vista do usuário, como os ativos, funções, pontos de entrada e outros. A análise dinâmica é conduzida na camada da plataforma e nos serviços e Application Programming Interfaces (API) do backend, que são locais em que as requisições e respostas das aplicações podem ser analisadas. Os resultados são referentes, principalmente, a problemas de confidencialidade no trânsito, de autenticação e autorização, além de erros de configuração do servidor (Mueller; Schleier; Willemsen, 2019).

O SAST e DAST podem ser adotados pelas próprias equipes de desenvolvimento no contexto do DevSecOp, que é um conceito importante que pode ser seguido para o desenvolvimento de software, ao integrar os testes de segurança na esteira de desenvolvimento, envolvendo a integração contínua e a entrega contínua (Constantin, 2020).

Todos eles permitem mapear e indicar as vulnerabilidades, com suas implicações e gravidade em relação aos riscos de invasão.

Blackbox vs. Whitebox

O teste Black-box envolve realizar a avaliação de segurança com um conhecimento mínimo ou nulo do sistema alvo, não tem conhecimento interno da aplicação ou da rede de computadores, simulando uma perspectiva de ataque realista.

O teste White-box, por outro lado, envolve testadores que têm conhecimento completo e detalhado do sistema alvo, incluindo informações internas e códigos-fonte, endereços IP, como é realizada a configuração do sistema, atividades de auditoria, entre outras, de conhecimento obrigatório da pessoa que conduz o teste, o que permite uma avaliação mais profunda e específica. Esse tipo de teste é mais rápido do que o de caixa preta, porque a transparência e o conhecimento permitem a construção de casos de teste mais sofisticados e granulares (Mueller; Schleier; Willemsen, 2019).